

Core Platform Framework

기술표준서

개발자 · 아키텍트 · Reviewer · 보안/품질 담당자

문서 목적	CPF 를 사용하는 Source/API/Transaction/Log/Security/Test/배포의 필수 기술 규칙과 금지 패턴을 정의합니다.
Repository / Branch	freeangelsun/202412_01_CPF / master
기준 Source / 정보	Repository f6d7080c5a14b7dd7595093f9497470169e18d80 Product Source f0aa49f29cba3cfd6ae12b0ddd4e118d05fff16c 최상위 요구사항 cpf-docs/governance/CPF_FINAL_TARGET_REQUIREMENTS.md 문서 표준 cpf-docs/specification/CPF_DOCUMENTATION_STANDARD.md
문서 성격	완성 기준 사용자 문서. 제품이 완료된 상태에서 사용자가 설치·개발·운영·복구·검 증 업무를 끝낼 수 있도록 정상 절차, 실패 판정, 복구, 확인 근거를 기술합니다.

읽는 방법 먼저 “빠른 찾기”에서 질문을 찾고, 상세 설명은 각 기능의 정보 절로 이동하십시오. 다른 매뉴얼은 같은 내용을 반복하지 않고 정보 절을 참조합니다.

빠른 찾기 - 질문에서 정보 절로

개발자가 묻는 질문	이 문서의 정보 위치	다른 문서 연결
API 는 어떻게 설계?	§4~§6	계층/API/OpenAPI
Transaction 표준은?	§7	Owner Local TX
Retry/Timeout 은?	§8	Resilience
보안/감사는?	§9	Permission/Secret/Masking/Audit
Test 기준은?	§11	Unit/Integration/Fault/Browser

완성 기준 이 문서는 제품 완료 상태에서 사용자가 수행할 최종 업무 계약을 기술합니다. 각 절은 선행조건 → 입력/설정 → 실행 → 정상 판정 → 실패/부분 실패 → 복구/대사 → Evidence 순서로 단으며, Source Trace 는 구현 위치를 제공합니다.

1. 적용 원칙

- 실제 Public Contract 를 우선하고 Internal package 를 외부에서 사용하지 않습니다.
- 업무 Owner 가 상태/원장을 소유하고 운영 제품이 직접 Table 을 수정하지 않습니다.
- 시험은 명령, 입력, 기대 결과, 실제 결과, Evidence 를 남기고 정상/오류/복구 시나리오를 모두 통과해야 변경 완료로 판정합니다.

2. Package / Module 표준

```
com.cpf.<owner>.api
com.cpf.<owner>.spi
com.cpf.<owner>.internal
```

금지	이유
Core→Common/Admin/Batch/업무 역참조	경량 Core/의존 방향 붕괴
Internal 직접 import	호환성/교체 불가
OSS 구현 Type 을 Public API 에 노출	Provider 교체/버전 종속
업무 Domain 간 DB 직접 접근	Owner/Transaction 경계 붕괴

3. Starter/Dependency 표준

- Profile 이 resolved Leaf 목록과 version 을 고정합니다.
- Mega Starter(all/full/everything) 금지
- 선택하지 않은 provider 의 Bean/SQL/Secret 요구 금지
- Aggregate Starter 는 dependency 만 소유

4. Application 계층 표준

계층	책임
API	DTO/Validation/Auth context
Application	Use case/Transaction orchestration
Domain	업무 규칙/상태
Persistence	Owner DB mapping
Integration Adapter	외부 protocol/provider

5. Query/Paging/Export 표준

- page 는 0-based 표준과 상한을 사용합니다.
- Sort field 는 allow-list 로 SQL 식별자 injection 을 차단합니다.
- 대량 Export 를 일반 Page API 메모리 적재로 처리하지 않습니다.

- 외부 Cursor 는 Signed Codec 을 사용하고 단순 Base64 를 신뢰하지 않습니다.

6. HTTP·OpenAPI·JavaDoc 표준

- operationId 를 일관되게 유지해 Generated Client 와 연결합니다.
- Error taxonomy/409/timeout/unknown 의미를 API 계약에 반영합니다.
- Public API/SPI 와 복구/동시성/보안 로직에는 JavaDoc 을 제공합니다.

7. Transaction 표준

상황	표준
하나의 Owner DB	필요한 Current/History/Audit/Outbox 를 Local TX 로
외부 HTTP/Broker/다른 DB	같은 Local TX 로 설명 금지
응답 유실	Commit 여부 확인 전 UNKNOWN_RESULT
원격 확정 후 로컬 실패	원격 자동 rollback 가정 금지; compensation/reconcile
동시성	expectedVersion/lock/idempotency 명시

8. Timeout·Retry·Resilience 표준

- 전체 timeout budget 을 caller→provider 로 나눕니다.
- Retry 는 오류 유형과 idempotency/부작용 가능성을 함께 판정합니다.
- Circuit breaker/bulkhead/rate limit 상태를 오류 taxonomy 와 운영 metric 에 연결합니다.
- retry attempt 마다 lineage 를 남깁니다.

9. Security·Permission·Masking·Approval·Audit 표준

축	규칙
AuthN	사용자/서비스 identity 분리
AuthZ	서버 최종 판정; Menu/Action/API/Field/Data Scope
Secret	Source/문서/로그 평문 금지
Masking	응답 DTO/Log/Export 에서 classification 기반
Approval	Reason + policy snapshot + SoD
Audit	actor/action/target/version/result/reference, immutable 지향
Break-glass	기간/범위/사후 Review

10. Logging·Observability 표준

- transactionId/segment/attempt/trace/instance 를 연결합니다.
- NOT_APPLICABLE 과 MISSING/FAILED/STALE 을 구분합니다.
- DB Commit 성공과 FileLog 기록 성공을 별도 판정합니다.
- Secret/Token/PII 원문을 기록하지 않습니다.

11. Test 표준

Test	최소
Unit	validation/domain/state
Integration	DB/API/provider
Contract	Local/Remote/OpenAPI
Concurrency	duplicate/version/race
Fault	timeout/response loss/process kill/disk/broker

Test	최소
Browser	권한/route/409/partial
Recovery	restart/reprocess/reconcile/rollback

12. 배포/변경 표준

- Artifact checksum/SBOM/signature 와 Config version 을 기록합니다.
- DB Migration 과 App rollback 을 독립적으로 계획합니다.
- Rolling/Canary/Blue-Green 은 version/drift/health 를 검증합니다.

관련 정보 문서

개발 절차 → [../guides/01_개발자매뉴얼.pdf](#) / 전체

운영 절차 → [../guides/05_플랫폼운영매뉴얼.pdf](#) / 전체

DB 표준 → [데이터베이스표준서.pdf](#) / 전체

13. Code Review Gate

Review 질문	실패 기준
Owner 가 명확한가?	공통이라고 Core/Common 에 업무 로직 삽입
Public 계약인가?	Internal import/OSS type leak
Transaction 경계가 맞나?	remote DB 를 local rollback 으로 설명
Idempotency 가 필요한가?	blind retry 가능
Error 가 분류됐나?	timeout/unknown 을 500 하나로 합침
Permission 은 서버가 판정?	UI hide 만 존재
Secret/PII 안전?	raw payload/log/export 노출
Test 가 실제 경계를 검증?	happy path only
운영 인계 가능?	operation/log/metric/audit 연결 없음

14. 금지 패턴 Catalog

패턴	왜 금지	대안
URL/Port 하드코딩	Topology 변경 불가	Registry/Config
SQL sort 문자열 직접 연결	Injection	allow-list
UUID 로 transactionId 재생성	계보 단절	TransactionContext
timeout 이면 바로 retry	중복 부작용	UNKNOWN lookup
catch(Exception) 후 성공	장애 은폐	Error taxonomy
Admin DB direct update	업무 불변식 우회	Owner Command
Secret default in source	유출	Secret provider/env
무제한 queue/cache	자원 고갈	bounded + metric/backpressure
Test mock 만으로 multi-instance 완료	실행 근거 없음	runtime/fault test

15. 변경 유형별 필수 Test

변경	필수
Public API	unit/contract/OpenAPI/generated client
Persistence/SQL	DB integration/migration/rollback/DB vendor parity
Transaction	conflict/idempotency/timeout/response loss

변경	필수
Messaging	duplicate/replay/DLQ/broker outage
Gateway	route/auth/security/timeout/failover/partial apply
ADM/BZA UI	permission/route/browser/409/partial
Batch	restart/process kill/partition/lease
Config/Secret	invalid/missing/rotation/restart

16. API Error Mapping 권고 표준

범주	HTTP 예	내부 의미	주의
Validation	400/422	입력/업무 사전조건	stack/internal detail 노출 금지
Unauthenticated	401	인증 없음/만료	credential detail 금지
Forbidden	403	권한/Data Scope	존재 여부 leakage 주의
Not found	404	resource 없음	IDOR 와 구분
Conflict	409	expectedVersion/idempotency conflict	reread
Rate limit	429	정책 제한	Retry-After 정책
Dependency/Transient	502/503	provider 장애	retry eligibility
Timeout/Unknown	504 또는 제품 error	결과 불명 가능	FAILED 로 단순화 금지

17. Observability Field 표준

Field	필수 범위	금지
transactionId	end-to-end	hop 마다 새 ID
segmentId/parent	remote/async/batch segment	parent 누락
attempt	retry/reprocess	attempt 덮어쓰기
operationId	long-running/unknown	response loss 후 새 operation 남발
trace/span	기술 호출	transaction 과 분리된 단독 로그
actor/service	auth identity	client 입력 그대로
reason/approval/audit ref	위험 조치	PII/secret 포함
error code/state	오류/상태	stack trace 만

18. 문서/Source 변경 동시성 표준

- Public API/Starter/Route/Property/SQL 이 변경되면 같은 변경 단위에서 Owner Document 를 현행화합니다.
- 다른 문서는 상세 내용을 복사하지 않고 링크/요약만 갱신합니다.
- Source·Test·SQL·API·문서는 같은 계약을 표현해야 하며, 어느 한쪽만 변경한 상태는 변경 완료로 판정하지 않습니다.
- 문서 생성 결과가 Source 를 앞서가는 신규 API/Class/Property 를 만들지 않습니다.

19. 변경 완료 판정 Gate

변경 유형	필수 종료 조건
Public API/SPI	Compatibility + JavaDoc + Unit/Integration + Consumer + 문서
Starter/Config	Catalog/AutoConfig/Provider Binding/Conflict/Property/Secret/Test/Guide
Transaction/Remote	Idempotency/Timeout/Unknown/Compensation/Fault/Multi-instance Trace
DB	Migration/rollback-forward/verify/drift/backup/restore + 3 Vendor parity

변경 유형	필수 종료 조건
ADM/BZA/Gateway	Route/Permission/Operation/Generated Client/Browser/Audit/Recovery
Batch	Metadata/Restart/Partition/Worker/Lease/Fencing/Reconcile/ADM
Security	negative corpus/Masking/Secret/SoD/Approval/Audit/Rotation

20. 변경 승인 Evidence 최소 세트

변경	승인 전에 첨부할 Evidence
API/SPI	before/after contract, JavaDoc, compatibility, consumer compile/integration result
Starter/Config	catalog diff, AutoConfiguration test, provider conflict/negative test, property reference
Transaction/Remote	timeout/response-loss/idempotency/compensation/multi-instance trace evidence
DB	migration checksum/history, 3 vendor verify, rollback/forward, restore/data reconcile
ADM/BZA/Gateway	route/permission/operation/generated client/browser/negative/recovery evidence
Batch	job metadata, restart/partition/worker/lease/fencing/reconcile/fault evidence
Security	negative corpus, masking, secret rotation, SoD/approval/audit evidence